

INTRODUCTION AU TEST D'INTRUSION

Règles d'engagement de la mission Harmattan x Sahel-Vert

TP 6 · Relire une mission



Contexte du mandat

Client : Coopérative Sahel-Vert.

Prestataire : Cabinet Harmattan.

Relecture demandée le 17 juin 2026 par Mariam Diallo.

Périmètre nominal : www.sahel-vert.example, portail.sahel-vert.example, mail.sahel-vert.example, vpn.sahel-vert.example, paie.sahel-vert.example, stock.sahel-vert.example.

Réseaux publics autorisés : 198.51.100.0/24 et 203.0.113.0/24.

Réseaux internes visibles en preuve minimale : 172.31.0.0/16 et 10.50.0.0/16.



Principes de journalisation

- ◆ Chaque action utile est consignée une seule fois dans le journal de mission.
- ◆ Les heures sont en UTC, au format ISO 8601 terminé par Z.
- ◆ Le journal peut contenir du bruit administratif normal.
- ◆ Un écart aux règles d'engagement se compte une seule fois par ligne de journal, même si plusieurs commentaires décrivent le même contexte.



Clauses opérationnelles

◆ RE-01. Périmètre explicite

- ◆ Toute action doit viser un actif explicitement listé dans le mandat.
- ◆ Une cible découverte en cours de mission n'entre pas automatiquement dans le périmètre.

◆ RE-02. Fenêtre d'intervention

- ◆ Fenêtre autorisée : du 15 au 17 juin 2026, chaque jour de 08:00:00Z à 18:30:00Z, bornes comprises.
- ◆ Une action en dehors de cette fenêtre reste un écart aux règles d'engagement, même si la cible reste dans le périmètre.

◆ RE-03. Preuve minimale

- ◆ La preuve doit rester factuelle, horodatée et limitée au minimum suffisant.
- ◆ La preuve acceptable cite l'actif observé et la méthode utilisée.

◆ RE-04. Notification préalable

- ◆ Toute action « creation-compte-test », « depot-artefact-retest » ou « lecture-config-etendue » doit porter un commentaire « notification=NOTIF-... ».
- ◆ La notification doit être envoyée avant l'action ; une mention « notification=absente » vaut écart.
- ◆ La notification vise Ibrahim Sanou ou son relais d'astreinte.

◆ RE-05. Actions interdites

- ◆ L'action « export-integral-donnees » est interdite.
- ◆ Une copie intégrale de données métier ne peut jamais servir de preuve minimale.

◆ RE-06. Quota de comptes de test

- ◆ Au plus 2 comptes de test peuvent rester actifs en même temps.
- ◆ La création d'un troisième compte actif constitue un écart, même si les comptes sont nominatifs et temporaires.

◆ RE-07. Nettoyage attendu

- ◆ Tous les comptes de test, jetons de démo, fichiers temporaires et exports locaux doivent être supprimés avant clôture.
- ◆ Le journal doit permettre de relier un artefact à son retrait ou à sa restitution.

◆ RE-08. Exception de re-test

- ◆ Un artefact peut rester en place jusqu'au re-test seulement si le commentaire contient « exception=RE-08 » et « retrait-prevu=AAAA-MM-JJ ».
- ◆ Cette exception doit rester limitée à un artefact clairement nommé, avec notification préalable.
- ◆ Un artefact laissé pour re-test n'est pas un écart si ces éléments sont présents et documentés.



Points de contact

RÔLE	NOM	CANAL
Cheffe de mission	Mariam Diallo	mission@harmattan.example
Testeur	Yao Kouassi	yao.kouassi@harmattan.example
Contact technique client	Ibrahim Sanou	ibrahim.sanou@sahel-vert.example
Contact juridique client	Rokia Bamba	rokoa.bamba@sahel-vert.example



Conditions d'arrêt

- 1 Arrêt immédiat si la stabilité ou l'intégrité métier paraît menacée.
- 2 Information immédiate du contact prévu avant toute reprise.
- 3 Conservation de la preuve minimale déjà recueillie, sans collecte supplémentaire.



Rappel de clôture

- ◆ Le prestataire remet un journal horodaté, une synthèse des écarts éventuels et une note de clôture.
- ◆ La note de clôture distingue les artefacts supprimés, les artefacts restants autorisés et les preuves conservées.
- ◆ Toute dérogation doit rester explicite, datée et attribuée.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.